SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

*I **G. PRANATHI [192472237]** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: G. PRANATHI

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

Question 1 — OSINT Email Enumeration Using theHarvester (20 Marks)

1. Aim

To perform an Open-Source Intelligence (OSINT) assessment of the publicly available information associated with tesla.com using theHarvester in Kali Linux and evaluate the social-engineering risks.

2. Tool and command

Tool used: Kali Linux — theHarvester

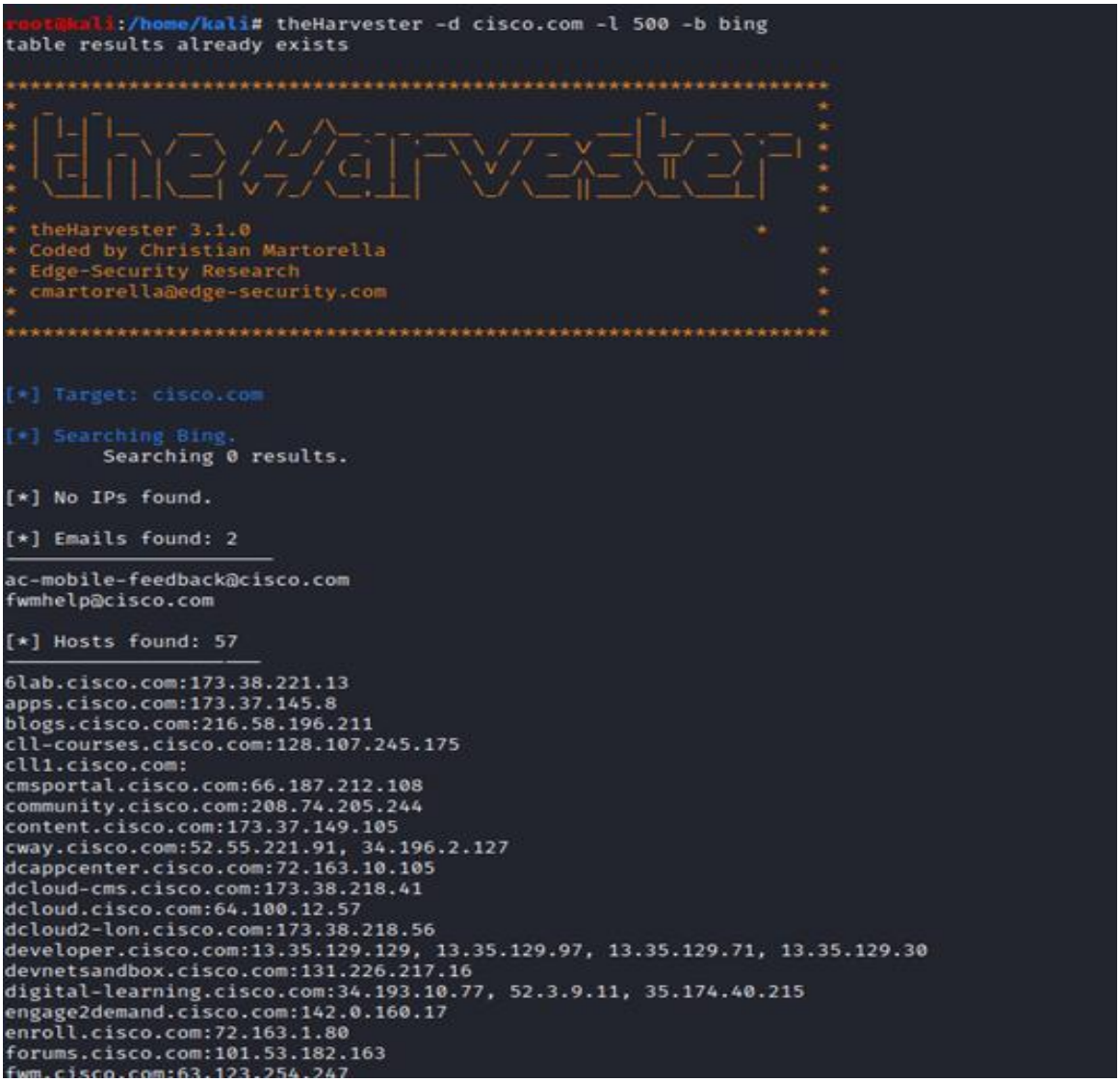
Open the Kali Linux terminal and execute:

theHarvester -d tesla.com -b all -l 100

- -d tesla.com specifies the domain being assessed.
- -b all requests supported public data sources.
- -l 100 sets the requested result limit.

The supported options and available data sources can differ by theHarvester version. If all is not supported, use a source listed by theHarvester -h. Only collect publicly available information and follow the applicable authorization and usage rules.

Output



3. Information to collect

Record your actual results under these categories.

Category	**Information to record**
Email addresses	Publicly indexed addresses, if found
Subdomains	Publicly discovered subdomains
Hosts	Hostnames associated with the domain
IP addresses	IP addresses returned by the tool
Data sources	Search engines or services that returned results

Screenshot to include: The Kali Linux terminal showing the command and its actual output. If no email addresses are returned, record that result rather than inventing addresses.

4. Categorization of email addresses

Classify only the addresses actually found. Do not assume an address exists because it follows a common naming pattern.

Likely role	Examples of role indicators
Support	support, helpdesk, customer-care
Sales	sales, business, partnerships
Human Resources	hr, careers, recruitment
Administration	admin, office, facilities
Technical Teams	security, engineering, it, devops

These are role indicators, not verified Tesla email addresses.

5. Risk analysis

The information collected through OSINT can help an attacker understand an organization's publicly visible digital footprint.

- Spear-phishing: Public role information may help an attacker tailor a deceptive message to a specific department.
- Credential harvesting: A fraudulent login page may be presented as a company service to trick users into disclosing passwords.
- Impersonation: Public employee names, job roles, and organizational terminology can be misused to make a message appear credible.
- Infrastructure reconnaissance: Subdomains and IP addresses may reveal publicly exposed services that need security review.
- Business impact: Successful attacks could lead to account compromise, unauthorized access, data exposure, and reputational damage.

The discovery of a public email address or subdomain does not, by itself, establish a vulnerability.

6. Countermeasures

1. Minimize unnecessary publication of employee contact details.
2. Configure email authentication using SPF, DKIM, and DMARC.
3. Enable multi-factor authentication (MFA), preferably phishing-resistant MFA for sensitive accounts.
4. Use secure email gateways and anti-phishing protection.
5. Regularly review public subdomains, DNS records, and exposed services.
6. Train employees to identify suspicious links, unexpected attachments, and requests for credentials.
7. Establish a clear process for reporting suspicious emails.
8. Monitor for impersonation attempts and unauthorized use of organizational branding.

7. Conclusion

TheHarvester helps security analysts understand what information about a domain is publicly discoverable. Categorizing the collected information supports risk assessment and helps prioritize measures to reduce employee exposure, impersonation, and phishing risks.

Question 2 — Phishing Awareness Simulation Using GoPhish (20 Marks)

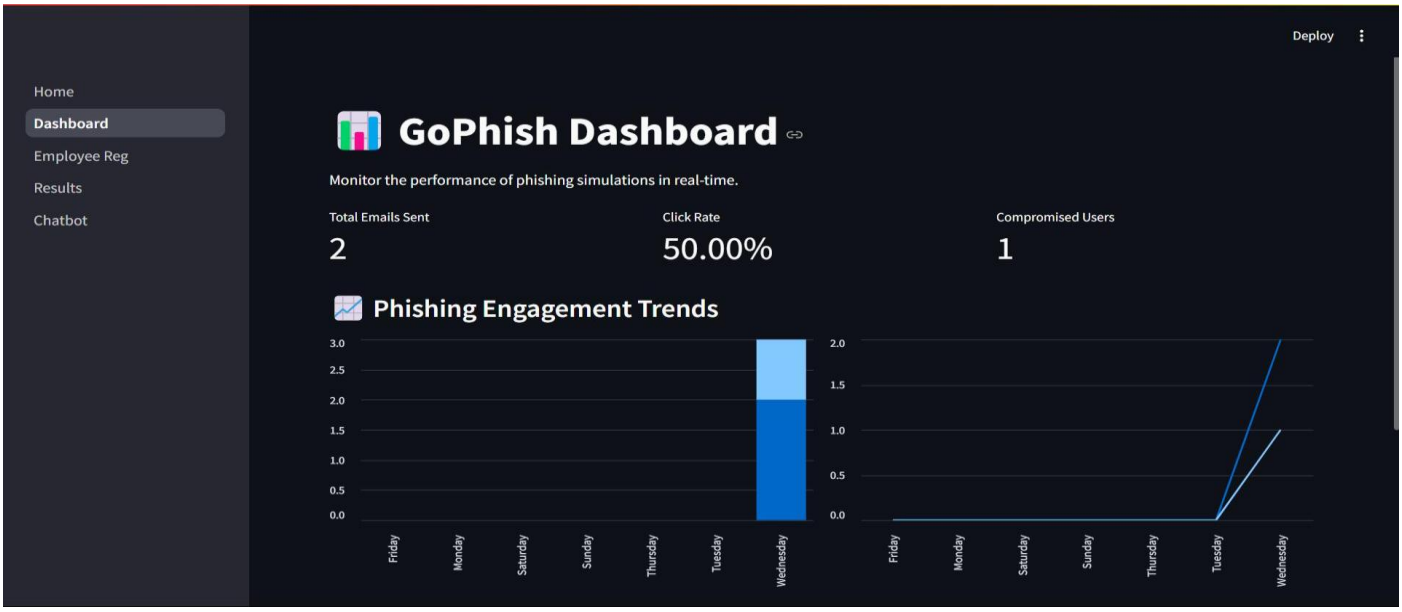
1. Aim

To conduct an authorized phishing-awareness simulation using GoPhish and dummy employee accounts, measure user interactions, and recommend improvements to organizational security awareness.

2. Tools required

- GoPhish
- A lab email server or approved test mail configuration
- Dummy employee accounts
- An authorized test domain or lab landing page
- A browser for viewing the campaign dashboard

Output



3. Procedure

1. Open GoPhish and sign in to the lab instance.
2. Create a recipient group containing the dummy employee accounts.
3. Create an educational email template using a clearly controlled simulation.
4. Configure an approved sending profile.

5. Create a landing page that records simulated interactions without collecting real passwords.
6. Create and launch the campaign within the authorized lab.
7. Review the dashboard and export the campaign report.
8. Record the delivery, open, and click results.

Screenshot to include: The GoPhish campaign configuration, dashboard, and report showing your actual lab results. Keep credentials and personal data out of screenshots.

4. Campaign metrics

Use the actual figures shown by GoPhish. Calculate the percentages as follows.

Metric	**Calculation**
Delivery rate	Delivered emails ÷ emails sent × 100
Email open rate	Emails opened ÷ delivered emails × 100
Click rate	Recipients who clicked ÷ delivered emails × 100

Use unique recipients for each numerator where possible, and clearly state the denominator used. Tracking limitations, such as blocked images or email privacy features, may affect open-rate accuracy.

5. Example results table

The following values are hypothetical examples only. Replace them with your campaign results.

Metric	**Example count**	**Example rate**
Emails sent	50	—
Emails delivered	45	90% of sent
Emails opened	27	60% of delivered
Recipients who clicked	9	20% of delivered

For example, the delivery rate is $45 \div 50 \times 100 = 90\%$.

6. Analysis of results

- Low delivery rate: Review the approved mail configuration, sender authentication, and delivery logs.
- High open rate: This indicates that many recipients opened the message, but does not prove that they trusted it.
- High click rate: This suggests that the simulated message persuaded a relatively large number of recipients to interact with it.
- Credential-entry attempts: If the lab measures these, use the number of unique participants who attempted submission. Never collect or retain real passwords.
- Attachment interactions: If simulated attachments are included, measure the number of participants who opened them and whether endpoint protections detected the activity.

A phishing simulation identifies training needs; it should not be used to shame or punish individual employees.

7. Recommendations

User awareness

- Conduct regular, short phishing-awareness training.
- Teach employees to verify unexpected requests through a separate trusted channel.
- Encourage reporting of suspicious messages.
- Provide immediate educational feedback after a simulation.

Email security

- Configure SPF, DKIM, and DMARC.
- Use spam filtering, URL analysis, and attachment sandboxing.
- Block known malicious links and file types where appropriate.
- Monitor suspicious sender impersonation.

Organizational policy

- Enforce MFA for business accounts.

- Prohibit password sharing and requests to send passwords by email.
- Establish a documented phishing-reporting and incident-response procedure.
- Repeat simulations and compare trends over time.

8. Conclusion

GoPhish provides a controlled way to evaluate employee responses to simulated phishing. Delivery, opening, and clicking metrics help identify weaknesses in awareness and email security. Combining user training, technical controls, and clear reporting procedures can reduce social-engineering risk.

Question 3 — Nmap Aggressive Scan of scanme.nmap.org (10 Marks)

1. Aim

To use Nmap's aggressive scan option to examine the permitted target scanme.nmap.org, identify discovered ports and services, and evaluate how reconnaissance information could contribute to social-engineering risks.

2. Tool and command

Tool used: Nmap

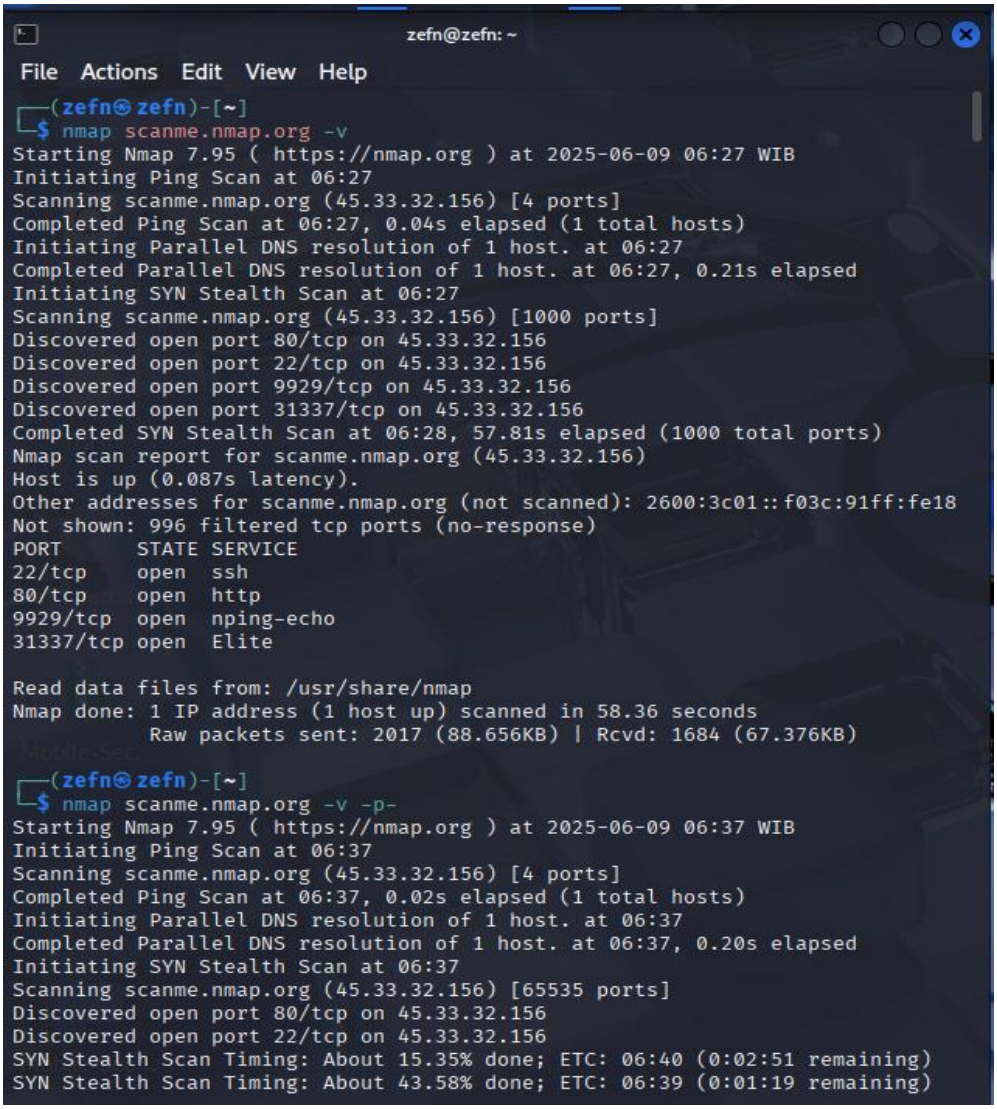
Run the following command in Kali Linux:

nmap -A scanme.nmap.org

The -A option enables several discovery features, including OS detection, version detection, default NSE scripts, and traceroute where supported.

Only scan the permitted scanme.nmap.org target. Follow the target owner's usage rules and do not perform denial-of-service testing or other disruptive activity.

Output



3. Information to record

Information	**Purpose**
Target hostname and IP	Identifies the resolved destination
Open ports	Shows which network services responded
Service versions	Helps assess software exposure
OS detection	Provides an estimated operating-system fingerprint
Script results	May reveal additional service information
Scan limitations	Records filtered ports, uncertainty, or incomplete detection

Screenshot to include: The terminal showing your actual nmap -A scanme.nmap.org command and output.

Do not copy the sample ports or versions from the illustrative image as if they were your results. Nmap output can change depending on the time, target configuration, network conditions, and detection accuracy.

4. Social-engineering risk analysis

An attacker could misuse technical reconnaissance findings to make fraudulent communications more believable.

1. Technical impersonation: Service names and operating-system clues could be used to imitate the language of an IT support message.
2. Targeted phishing: A message could falsely claim that a particular service needs an urgent update.
3. Pretexting: An attacker might pretend to be a support engineer and use technical terminology to gain trust.
4. Vulnerability research: Service-version information can help defenders determine whether patches or configuration changes are needed; an attacker might misuse the same information to identify potential weaknesses.
5. Business impact: If an employee trusts a fraudulent request, the organization could face credential compromise, unauthorized access, or malware infection.

A scan does not prove that a service is vulnerable or that a social-engineering attack has succeeded.

5. Defensive recommendations

- Keep operating systems and exposed services updated.
- Close unnecessary ports and restrict administrative services to trusted networks.
- Use firewalls and network monitoring to detect suspicious connections.
- Enforce MFA and least-privilege access.

- Train IT support staff to verify identity before approving account changes or sharing information.
- Establish a callback procedure using a known, trusted contact number.
- Monitor and review externally exposed assets regularly.
- Maintain an incident-response process for suspected phishing or impersonation.

6. Conclusion

Nmap helps security analysts identify visible network services and estimate system characteristics. These findings support asset management and patch prioritization, while also showing why IT teams need identity verification, access controls, and phishing awareness.